



취약점 대처하기

데이터 수집과 분석의 모든 노력은 결과를 어떻게 활용할지에 대한 명확한 목표가 없으면 헛수고가 됩니다. 이 장에서는 취약점 분석을 활용해 조직의 보안 수준을 향상시키는 방법을 다룹니다.

보안 조치 3가지

보안 조치의 세 가지 범주



패치

버그 및 취약점 해결을 위한 업데이트 적용. 가장 즉각적인 대응입니다.



완화

공격을 어렵게 만들거나 결과의 심각도를 낮추는 조치입니다.



체계적 조치

조직의 전반적인 보안 태세를 개선하는 사전 예방적 변화입니다.

이 세 가지 조치는 **심층 방어 전략**의 일환으로 중복적으로 조합하여 적용할 수 있으며, 각 제어 장치가 효과적인지 반드시 테스트해야 합니다.



패치: 가장 시급한 대응

패치란?

새로운 취약점 발견 후 가장 먼저 패치 존재 여부를 확인하고 즉시 적용해야 합니다. 공격자가 악용하기 전에 차단하는 것이 목표입니다.

패치 관리 도구

Microsoft SCCM과 같은 도구가 유용하지만, 모든 OS 및 장치에 중앙 집중식 도구가 사용 가능하지 않을 수 있습니다.

패치가 불가능한 경우

취약점이 너무 최근이거나, 소프트웨어 업데이트가 중단되었거나, 비즈니스 요구상 시스템 가동 시간이 우선시될 수 있습니다.

완화 조치의 종류

완화 조치는 공격을 더 어렵게 만들거나 피해 결과를 줄이는 광범위한 조치입니다.



애플리케이션 기반

취약한 모듈 비활성화 또는 공격 패턴 필터링



호스트 기반

방화벽, SELinux 등 OS 수준에서 공격 효과 제한



네트워크 기반

물리적 방화벽, IDS로 트래픽 차단 및 모니터링



임시 조치

패치 전까지 취약 호스트 접근 차단 — 영구 해결책은 아니지만 유용



영구적 조치

취약점 해결 후에도 기능에 영향 없으면 유지하여 추가 보안 제공



물리적 보안

USB 포트 에폭시 봉인 등 물리적 차단으로 데이터 유출 방지



사전 예방적 접근

체계적 조치

완화 조치가 사후 대응적이라면, 체계적 조치는 **사전 예방적**입니다.

예를 들어 MySQL 취약점에 내부 방화벽으로 포트(TCP 3306)를 차단한 후, "애초에 왜 이 포트가 열려 있었을까?"라는 질문을 던져야 합니다.

이런 시스템적 질문을 통해 조직 정책 및 구성 표준에 영향을 미치는 더 광범위한 보안 환경 개선을 이끌어낼 수 있습니다.

위험을 감수하세요

네 번째 선택지는 아무것도 하지 않는 것입니다. 위험 관리 용어로 위험 수용 (Acceptance)이라고 합니다.



언제 수용하는가?

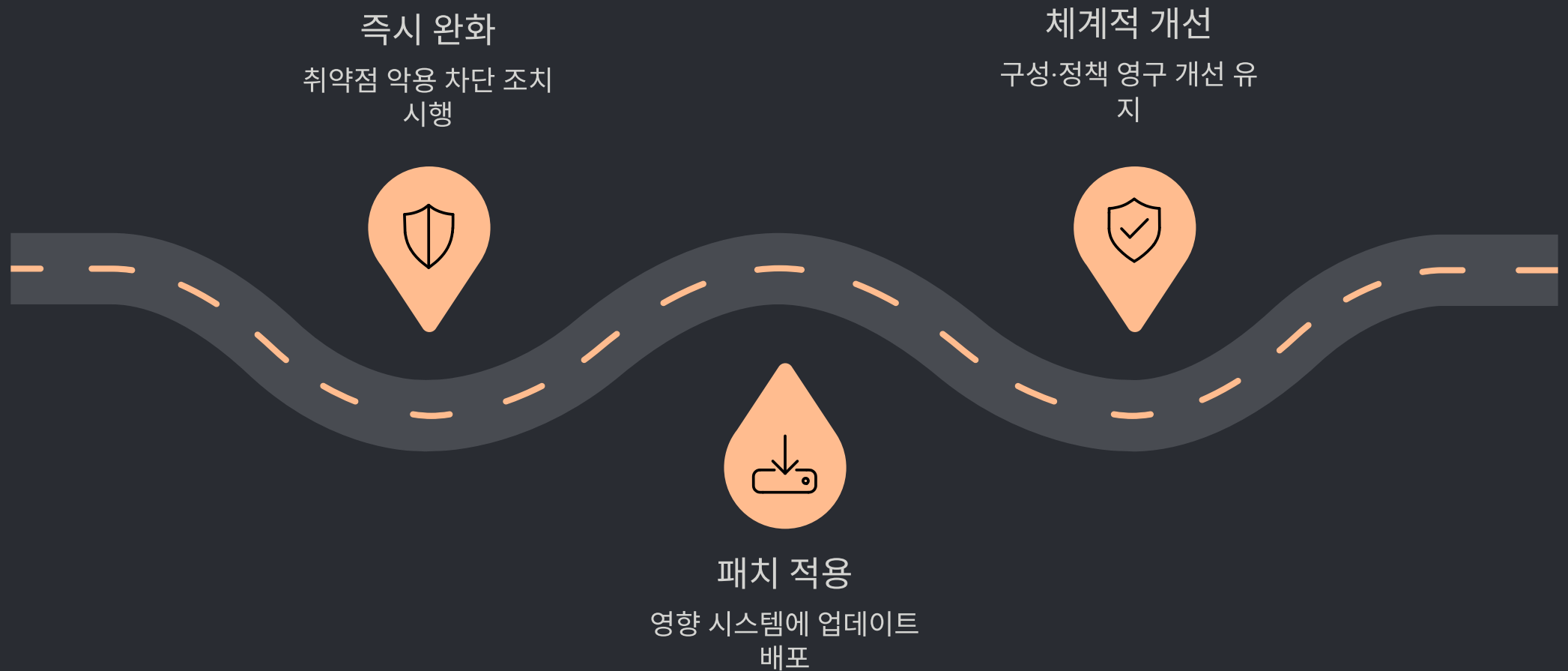
위험이 너무 드물거나 영향이 너무 적어 해결할 가치가 없다고 판단할 때입니다. 경우에 따라 최선의 선택일 수 있습니다.

반드시 문서화하세요

위험을 수용하더라도 조치 미이행을 문서화하고 이해관계자의 동의를 받아야 합니다. 감사관에게 단순 무시가 아닌 고려 후 수용이었음을 입증해야 합니다.

⚠ 문서화되지 않은 위험 수용은 인지하지 못한 위험과 externally 똑같아 보입니다!

심층 방어 (Defense in Depth)



중요 시스템에 즉시 패치가 불가능하더라도, 취약점 악용을 차단하는 완화 조치를 신속하게 시행할 수 있습니다. 패치 적용 후 극단적인 완화 조치는 제거하고, 개선된 구성은 유지합니다.

다층 방어의 힘: 한 계층의 실패가 다른 계층으로 보완됩니다. 예를 들어 MySQL 제로데이 취약점이 발생하더라도, 신뢰할 수 있는 호스트에서만 접근을 허용하는 기존 조치가 패치를 적용할 충분한 시간을 확보해 줍니다.

제어 조치 검증

검증의 중요성

패치·완화·시스템 변경 후, 선택한 조치가 실제로 효과적인지 반드시 테스트해야 합니다.

- 추가 스캔으로 취약점이 더 이상 보고되지 않는지 확인
- SSH 옵션 비활성화 등 미미한 변경은 수동 테스트가 효과적
- 패치가 잘못 적용되거나 누락될 수 있으므로 적극적 테스트 필요

MySQL 예시

원격 코드 실행 취약점에 패치를 적용했다면, 새 스캔에서 취약점이 사라져야 합니다.

완화 조치로 localhost 연결만 허용했다면, 공용 인터페이스에서 해당 포트가 닫혀 있어야 합니다.

❗ 어떤 것도 제대로 작동한다고 가정하지 마십시오!

네 가지 선택지 요약

1

패치 적용

가장 빠르고 직접적인 해결책. 가능한 즉시 적용하세요.

2

완화 조치

패치가 불가능할 때 공격을 어렵게 만들거나 피해를 줄입니다.

3

체계적 개선

미래 위협에 대비해 조직 보안 태세를 근본적으로 강화합니다.

4

위험 수용

영향이 적을 때 선택하되, 반드시 문서화하고 동의를 받으세요.

요약

환경에서 취약점을 발견했을 때 취할 수 있는 조치는 다음과 같습니다.

→ 즉각적 대응

패치 적용 또는 완화 조치로 취약점 악용을 즉시 차단

→ 체계적 개선

사후 분석을 통해 미래 위협에 대비한 보안 태세 강화

→ 위험 수용 및 문서화

필요시 위험을 수용하되, 반드시 문서화하고 이해관계자 동의를 받음

→ 제어 조치 검증

적용한 모든 조치가 실제로 취약점을 해결하는지 반드시 테스트

